

Relatório de Governança e Riscos

Documento que estabelece as regras de governança, privacidade, segurança e gestão de riscos do projeto **AIReport Gen-Experience**.

A solução utiliza Inteligência Artificial Generativa e arquitetura RAG (*Retrieval-Augmented Generation*) para interpretar relatórios genéticos de forma conversacional, com foco em:

- acessibilidade da informação;
- experiência do paciente;
- prevenção;
- apoio interpretativo;
- segurança e privacidade de dados sensíveis.

Sensibilidade dos Dados

Os relatórios processados pela solução contêm:

- predisposições genéticas;
- ancestralidade;
- informações metabólicas;
- riscos de doenças;
- hábitos de saúde;
- marcadores biológicos.

Esses dados são classificados como:

Dados pessoais sensíveis

Conforme a Autoridade Nacional de Proteção de Dados e a Lei Geral de Proteção de Dados (LGPD).

Limites do Agente de IA

O sistema foi projetado para atuar exclusivamente como:

- assistente interpretativo;
- mecanismo de simplificação de linguagem;
- ferramenta educacional e preventiva.

O agente NÃO deve:

Restrição	Descrição
Emitir diagnóstico médico	Não realiza confirmação clínica
Prescrever medicamentos	Não recomenda tratamentos
Substituir profissionais	Não substitui médicos/geneticistas
Fazer prognósticos definitivos	Apenas contextualiza predisposições
Gerar conclusões fora do relatório	Responde apenas com base no contexto recuperado
Inferir doenças não presentes	Bloqueio de extrapolação

Guardrails Implementados

1. Prompt Engineering

O *system prompt* força:

- linguagem amigável;
- tom não alarmista;
- foco preventivo;
- respostas fundamentadas apenas no relatório;
- proibição explícita de diagnósticos.

Exemplo de regra aplicada

Você não deve fornecer diagnósticos médicos.

Você deve responder apenas utilizando informações recuperadas do relatório genético.

Caso a informação não exista no contexto, informe claramente que o relatório não contém essa informação.

2. Arquitetura (RAG)

A solução utiliza arquitetura RAG para reduzir alucinações.

Fluxo:

Pergunta do usuário

↓

Busca semântica no ChromaDB

↓

Recuperação dos trechos relevantes

↓

LLM recebe apenas o contexto encontrado

↓

Resposta contextualizada

Benefícios:

- maior rastreabilidade;
- redução de respostas inventadas;
- controle do contexto;
- explicabilidade.

3. Limitação de Escopo

O modelo não possui:

- acesso à internet;
- acesso a bancos médicos externos;
- memória persistente de usuários;
- autonomia de execução;
- integração hospitalar real.

Política de Privacidade

Dados

No protótipo acadêmico:

Tipo	Local
-------------	--------------

PDF genético	data/raw/
--------------	-----------

Base vetorial	data/vectordb/
---------------	----------------

Embeddings	ambiente local
------------	----------------

Conversas	memória temporária
-----------	--------------------

Nenhum dado é enviado para APIs externas quando utilizando:

- Ollama local;
- modelo Mistral local.
-

Processamento Local

A utilização de LLM local foi escolhida estrategicamente para:

- reduzir exposição de dados;
- evitar envio de informações genéticas para terceiros;

- aumentar privacidade;
- reduzir dependência cloud.

Isso representa um diferencial importante em ambientes de saúde.

Retenção de Dados

No estado atual do projeto:

- não existe retenção permanente de conversas;
- o histórico é apenas temporário;
- o PDF permanece localmente até exclusão manual.

Consentimento

Em cenário produtivo real, seria necessário:

- consentimento explícito do usuário;
- aceite de termos de uso;
- autorização para tratamento de dados sensíveis;
- política de retenção transparente.

Riscos da Solução

Risco	Impacto Mitigação	
Alucinação da IA	Alto	RAG + prompt restritivo
Interpretação incorreta	Alto	Disclaimers obrigatórios
Vazamento de dados	Alto	Processamento local
Dependência excessiva do usuário	Médio	Avisos de não substituição médica
Respostas alarmistas	Médio	Engenharia de prompts
Dados incompletos	Médio	Explicação de limitações
Reindexação incorreta	Baixo	Persistência vetorial controlada

Disclaimers

A interface e o sistema devem apresentar continuamente avisos como:

As respostas possuem caráter exclusivamente informativo e educacional.

A solução não substitui consulta médica, diagnóstico clínico ou acompanhamento profissional especializado.

E também:

Predisposição genética não representa confirmação de doença.

Fatores ambientais e hábitos de vida também influenciam os resultados.

Conformidade Regulatória

LGPD

A solução considera princípios da:

Lei Geral de Proteção de Dados

especialmente:

- finalidade;
- necessidade;
- segurança;
- prevenção;
- transparência.

Saúde Digital

O sistema NÃO é:

- dispositivo médico;
- ferramenta diagnóstica;
- software clínico homologado.

Portanto, o projeto é classificado como:

Sistema de apoio informacional e interpretação assistida.

Estratégia de Segurança

Em evolução produtiva:

Recurso	Objetivo
HTTPS/TLS	criptografia
Autenticação	proteção de acesso
Criptografia AES	proteção de PDFs
Controle RBAC	segregação de perfis
Logs auditáveis	rastreabilidade
Expurgo automático	retenção mínima
Vault de segredos	proteção de credenciais

Ética e Uso Responsável de IA

A solução segue princípios de:

- IA explicável;
- IA responsável;
- transparência;
- minimização de danos;
- apoio humano;
- supervisão médica.

O objetivo do sistema é:

Democratizar o acesso à interpretação genética de forma segura, preventiva e acessível.

e não substituir profissionais de saúde.